MERGE

HITRUST r2 Gap Assessment Report

2026

Proprietary and Confidential

Table of Contents

SECTION 1 HITRUST GAP ASSESSMENT REPORT..... 1

EXECUTIVE SUMMARY.....2
SCOPE.....2
SUMMARY OF CONTROL GAPS AND RECOMMENDATIONS.....2

SECTION 2 ASSESSMENT RESULTS..... 4

CONTROL FINDINGS.....5
CONCLUSION & RECOMMENDATIONS.....5
SUMMARY SCORES.....6

DRAFT

SECTION 1

HITRUST GAP ASSESSMENT REPORT

DRAFT

To: MERGE February 27, 2026

EXECUTIVE SUMMARY

MERGE ('the Company') is scheduled to undergo a HITRUST Validated Assessment in 2026 for its MERGE Marketing Solution services (the 'Services') in accordance with the HITRUST CSF Framework. The purpose of the Validated Assessment will be to assess and score the Company's Policies, Procedures and implemented controls designed to meet the HITRUST CSF requirement statements. This r2 Gap Assessment is a proactive project designed to identify control weaknesses within the design of MERGE's control environment that does not meet HITRUST's CSF requirements, and provide recommendations to remediate any gaps.

A-LIGN was engaged by MERGE to perform a HITRUST r2 Gap Assessment to determine the Company's conformance with the HITRUST implementation requirements for the Version 11.5 CSF Security Assessment. Based on the scoping responses provided by the Company and the results generated from MyCSF, 204 implementation requirements were evaluated as part of this assessment.

SCOPE

Organization and Industry Segment Overview

MERGE is a unified creative agency with locations in Boston, Atlanta, Chicago, Kansas City, Denver, and New York. It expertly combines strategy, creativity, media, and technology to propel clients' brands and businesses forward. Established in 1986 as Partners & Simons, MERGE Boston is renowned for its expertise in the healthcare and financial services sectors. In 2012, Partners & Simons was acquired by Myelin Health Communications, a Baird Capital company. The agency was re-branded as MERGE in 2018 following its purchase by Keystone Capital.

The Information Security Program is seamlessly integrated into the Information Technology operations at MERGE, with four essential roles: the Director of Information Security, Privacy Officer, Senior Vice President of Information Technology, and the Executive Leadership Team. Leading the program, the Director of Information Security is responsible for the design, testing, enforcement, and monitoring of security controls. In collaboration with the Director, the Privacy Officer ensures the confidentiality of the company's accessed or stored records. The Senior Vice President of Information Technology works closely with the Director to uphold security policy compliance and assists in drafting procedures to ensure a secure and standardized IT workflow across the agency. The Executive Leadership Team (ELT), which includes the Chief of Operations, President, Executive and Senior Vice Presidents of MERGE practice areas and shared operations, provides leadership and strategic guidance.

Services/Products Provided

MERGE is a creative and media agency offering clients an uncommon depth of expertise in both strategy and technology. MERGE creates integrated communications and design experiences across all media to help clients build trust and drive business at every point of contact.

Primary Systems

The MERGE Marketing Solution is leveraged with Google Workspace Enterprise and Entra ID to enhance knowledge and the work span fluidly across strategy, creative, web design and development, media, analytics, and more.

Scope Overview Table

DRAFT

System Name	Components	Service Offering	Full	Partial	With Exclusions	Description of Exclusions
MERGE Marketing Solution	Google Workspaces	Marketing services	X			

Services Outsourced

- Microsoft Azure: MERGE leverages Azure to host Active Directory and enable a unified Single Sign-On (SSO) platform, simplifying identity management and improving secure access for users.
- Google Cloud Platform: Google Cloud provides and maintains the physical infrastructure and environmental security required to operate hosted services. This ensures a secure, resilient foundation for all cloud-based workloads.
- Foresight Cybersecurity: This service leverages a Security Operations Center to analyze and triage Google SecOps logs, providing continuous threat detection and incident response support.

SUMMARY OF CONTROL GAPS AND RECOMMENDATIONS

A-LIGN performed Phase 1 of the Gap Assessment during the weeks of 01/26/2026-02/06/2026. Phase 2 of the Gap Assessment will be scheduled once document remediation is complete.

Inquiry with management and inspection of documented evidence such as policies, procedures and system configuration settings were the primary methods of testing used to determine MERGE's compliance with the HITRUST CSF control statements. A-LIGN only reviewed evidence for one maturity level: Implemented. Policy, Process, Measured and Managed were not reviewed as part of this phase of the Gap Assessment.

The high-level summary of potential control gaps noted during this assessment are mentioned in the table below. Additionally, specific control gaps are noted within the offline spreadsheet attached in section 2 of this report. Management should consider implementing effective controls to mitigate all gaps and implement necessary controls before undergoing the HITRUST Validated Assessment.

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
01.00aAISecOrganizational.1	00.a Information Security Management Program	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines: security administration - defines: data governance - defines: software development - defines: risk management - defines: incident management - defines: business continuity - defines: disaster recovery
01.02aAISecOrganizational.1	02.a Roles and Responsibilities	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines: roles and responsibilities for governance - defines: roles and responsibilities for security - defines: roles and responsibilities for risk management Further, management should ensure that the organization assigns human accountability for the actions performed by, outputs produced by, and decisions made by the organization's deployed AI systems
01.03aISO23894Organizational.12	03.a Risk Management Program	AI policies and procedures considering the	Management should ensure that AI policies and procedures are

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
	Development	details of the requirement statement are not formally maintained at this time.	developed considering the following: - defines relative legal requirements related to AI - defines guidelines on ethical use and design of AI - defines domain-specific guidelines and frameworks related to AI - defines technology trends and advancements related to areas of AI - defines societal and political implications of the deployment of AI systems - defines external stakeholder perceptions, needs, and expectations - defines how the use of AI can affect the ability of the organization to meet contractual obligations and guarantees - defines contractual relationships during the design and production of AI systems and services - defines how the use of AI can increase the complexity of networks and dependencies - defines how an AI system can replace an existing system - defines the risk benefits and risk transfers of an AI system versus the existing system can be undertaken, considering safety, environmental, social, technical and financial issues
01.03aISO23894Organizational.13	03.a Risk Management	AI policies and procedures	Management should ensure that AI policies

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
	Program Development	considering the details of the requirement statement are not formally maintained at this time.	and procedures are developed considering the following: - defines the effect that an AI system can have on the organization's culture by shifting and introducing new responsibilities, roles and tasks - defines any additional international, regional, national and local standards and guidelines that are imposed by the use of AI systems - defines the additional risks to organizational knowledge related to transparency and explainability of AI systems - defines that the use of AI systems can result in changes to the number of human resources needed to realize a certain capability, or in a variation of the type of resources needed - defines the specific knowledge in AI technologies and data science required to develop and use AI systems - defines the availability of AI tools, platforms and libraries which can enable the development of AI systems without there being a full understanding of the technology, its limitations and potential pitfalls - defines the potential for AI to raise issues and opportunities related to intellectual property for specific AI systems

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			- defines how AI systems can be used to automate, optimize and enhance data handling - defines additional quality and completeness constraints on data and information can be imposed by AI systems - defines how the use of AI systems can increase the complexity of interdependencies and interconnections - defines the consideration that the use of AI systems can increase the need for specialized training
01.03aISO23894Organizational.25	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - AI system project-level processes are aligned with the organization's objective
01.03aISO31000Organizational.1	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - assesses the following risk criteria: nature and type of uncertainties that can affect outcomes and objectives (both tangible and intangible) - assesses the following risk criteria: how consequences (both positive and negative) and likelihood will be defined and measured - assesses the following risk criteria: time-related

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			factors - assesses the following risk criteria: consistency in the use of measurements - assesses the following risk criteria: how the level of risk is to be determined - assesses the following risk criteria: how combinations and sequences of multiple risks will be taken into account - assesses the following risk criteria: the organization's capacity
01.03aISO31000Organizational.2	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - assesses the following risk criteria: tangible and intangible sources of risk - assesses the following risk criteria: causes and events - assesses the following risk criteria: time-related factors - assesses the following risk criteria: changes in the external and internal context - assesses the following risk criteria: how the level of risk is to be determined - assesses the following risk criteria: how combinations and sequences of multiple risks will be taken into account - assesses the following risk criteria: the organization's capacity - assesses the following

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			risk criteria: threats and opportunities - assesses the following risk criteria: vulnerabilities and capabilities - assesses the following risk criteria: the nature and value of assets and resources - assesses the following risk criteria: consequences and their impact on objectives - assesses the following risk criteria: indicators of emerging risks - assesses the following risk criteria: limitations of knowledge and reliability of information - assesses the following risk criteria: biases, assumptions and beliefs of those involved
01.03aISO31000Organizational.3	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines how to figure out the likelihood of events and consequences - defines how to figure out the nature and magnitude of consequences - defines how to figure out the effectiveness of existing controls - defines sensitivity and confidence levels - defines complexity and connectivity requirements - defines time-related factors and volatility
0181.06a1Organizational.12	06.a Identification	Applicable Legislation is not	Management should ensure that the

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
	of Applicable Legislation	included within the defined documentation.	policy/procedure includes the applicable legislation.
0183.07b1Organizational.1	07.b Ownership of Assets	All asset inventories are not formally documented.	Management should ensure that all inventories for in-scope assets are maintained in accordance with the requirement statement
0302.09o1Organizational.3	09.o Management of Removable Media	Log of removable media transport is not currently maintained with the accountable individuals.	Management should ensure that a formalized removable media transport log is drafted and includes the accountable individuals.
0304.09o1Organizational.2	09.o Management of Removable Media	Policy and procedure documentation does not currently address the requirements around removable media. Further, A-LIGN was unable to gain assurance that USB's are technically restricted on devices where they are not explicitly approved for use.	Management should ensure that the current policies and procedures are updated to account for the proper removable media requirements. Further, management should ensure that USB's are technically restricted on devices where they are not explicitly approved for use.
0311.09o1Organizational.5	09.o Management of Removable Media	Policy and procedure documentation does not currently address the requirements around removable media. Further, A-LIGN was unable to gain assurance that removable media is scanned prior to plugging in or that the removable media devices can be wiped prior to use.	Management should ensure that the current policies and procedures are updated to account for the proper removable media requirements. Further, management should ensure that removable media is scanned prior to plugging in or that the removable media devices can be wiped prior to use.
0321.09u1Organizational.2	09.u Physical Media in Transit	Policy and procedure documentation does not currently address	Management should ensure that the current policies and procedures

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		the requirements around removable media.	are updated to account for the proper removable media requirements.
0330.09o1Organizational.4	09.o Management of Removable Media	Policy and procedure documentation does not currently address the requirements around removable media. Further, A-LIGN was unable to gain assurance that removable media is labeled accordingly (ex: approved/unapproved).	Management should ensure that the current policies and procedures are updated to account for the proper removable media requirements. Further, management should ensure that removable media is labeled accordingly (ex: approved/unapproved).
06.09bAISecSystem.1	09.b Change Management	A formal change management process is not in place for AI system development.	Management should ensure that a formal change management process is in place for AI system development. Merge will be moving to the Jira ticketing system to manage the development process. Workflow being developed will consider the following: - defines process for: documenting changes - defines process for: testing changes - defines process for: approving changes - defines process for: reviewing release notes
06.10hAISecSystem.4	10.h Control of Operational Software	AI Model cards are not maintained at this time.	Management should ensure that for any internally produced AI system, AI Model cards are developed and maintained and contain the following: - model card includes: model details

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			- model card includes: intended use - model card includes: training details - model card includes: evaluation details - model card includes: usage caveats
06.10hAISecSystem.5	10.h Control of Operational Software	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines process for: documenting changes - defines process for: testing changes - defines process for: approving changes
06.10hAISecSystem.6	10.h Control of Operational Software	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - system documentation includes: creation, operation, and lifecycle management of any models - system documentation includes: datasets (including data used for training, tuning, and prompt enhancement via RAG) - system documentation includes: configurations (e.g., meta prompts) - system documentation includes: language model tools and plugins - system documentation includes: tooling resources (e.g., AI platforms, model engineering

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			environments) - system documentation includes: system and computing resources - system documentation includes: human resources needed for development and operation Further, management should ensure that any changes are formally documented within a ticketing system.
06.10hAISecSystem.7	10.h Control of Operational Software	A formal change management process is not in place for AI system development.	Management should ensure that a formal change management process is in place for AI system development. Merge will be moving to the Jira ticketing system to manage the development process. Workflow being developed will consider the following: - an explicit linkage between the versions of the training dataset used, the pipeline configuration used, and the resulting AI model.
06.10jAISecSystem.1	10.j Access Control to Program Source Code	An AI Inventory is not currently maintained.	Management should ensure that an AI inventory is developed using Google sheets and contains the following details: - artificial intelligence assets are tracked - artificial intelligence asset tracking includes: code to create, train, and/or deploy AI models - artificial intelligence asset tracking includes:

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			training datasets - artificial intelligence asset tracking includes: fine-tuning datasets - artificial intelligence asset tracking includes: RAG datasets (if used) - artificial intelligence asset tracking includes: configurations of pipelines used to create, train, and/or deploy AI models - artificial intelligence asset tracking includes: code used by language model tools such as agents and plugins (if used) - artificial intelligence asset tracking includes: models
0636.10k1Organizational.3	10.k Change Control Procedures	Policy does not include - defines management's commitment to program - defines enterprise coordination - defines compliance requirements	Management should ensure that the policies and procedures for configuration management address all the components outlined within the requirement statement.
06900.09d1System.2	09.d Separation of Development, Test, and Operational Environments	A-LIGN was unable to gain assurance that there is a separation between development and production environments.	Management should ensure that a separation between the development and production environments is implemented.
07.06hAISecOrganizational.1	06.h Technical Compliance Checking	AI security assessments (penetration tests) are not currently completed at this time.	Management should ensure that AI security assessments (penetration tests) are completed on at least an annual basis. Further, management should ensure that prior to any significant model changes, an appropriate

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			risk assessment should be conducted.
07.07a1Organizational.8	07.a Inventory of Assets	All inventories are not formally documented.	Management should ensure that all inventories for in-scope assets are maintained.
07.07aAISecOrganizational.3	07.a Inventory of Assets	An AI Inventory is not currently maintained.	Management should ensure that an AI inventory is developed using Google sheets and contains the following details: - artificial intelligence assets are tracked - artificial intelligence tracking includes: system owner - artificial intelligence tracking includes: system sensitivity/risk categorization - artificial intelligence tracking includes: models Further, management should ensure that the inventory is reviewed at least every 180 days
07.07aAISecOrganizational.4	07.a Inventory of Assets	An AI Inventory is not currently maintained.	Management should ensure that an AI inventory is developed using Google sheets and contains the following details: - artificial intelligence asset tracking includes: code to create, train, and/or deploy AI models - artificial intelligence asset tracking includes: training datasets - artificial intelligence asset tracking includes: fine-tuning datasets - artificial intelligence asset tracking includes:

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			RAG datasets (if used)
07.07aAISecOrganizational.5	07.a Inventory of Assets	An AI Inventory is not currently maintained.	Management should ensure that an AI inventory is developed using Google sheets and contains the following details: - artificial intelligence asset tracking includes: code to create, train, and/or deploy AI models - artificial intelligence asset tracking includes: training datasets - artificial intelligence asset tracking includes: fine-tuning datasets - artificial intelligence asset tracking includes: RAG datasets (if used) - artificial intelligence asset tracking includes: dataset creation dates and sensitivity levels Further, management should ensure that the inventory is reviewed at least every 180 days
07.07aISO23894Organizational.2	07.a Inventory of Assets	An AI Inventory is not currently maintained.	Management should ensure that an AI inventory is developed using Google sheets and contains the following details: - AI data - AI models - AI systems
07.10bAISecSystem.1	10.b Input Data Validation	A-LIGN does not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against these configurations: - configured to filter user

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			inputs for suspicious and/or unexpected values/patterns
07.10bAISecSystem.2	10.b Input Data Validation	A-LIGN does not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against: - artificial intelligence model training is checked prior to usage - artificial intelligence model tuning is checked prior to usage - artificial intelligence prompt enhancement via RAG (if used) is checked prior to usage - identified anomalous entries are removed - checked using statistical methods - checked through manual inspection - checked through automated means
07.10eAISecSystem.1	10.e Output Data Validation	A-LIGN does not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against these configurations: - configured to prevent sensitive data contained within generative artificial intelligence model from being shown to end users
07.10mAISecOrganizational.2	10.m Control of Technical Vulnerabilities	A-LIGN does not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against: - cryptographic hashes and/or digital signatures

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			are checked for: downloaded artificial intelligence models - cryptographic hashes and/or digital signatures are checked for: downloaded artificial intelligence software packages - cryptographic hashes and/or digital signatures are checked for: downloaded artificial intelligence datasets - cryptographic hashes and/or digital signatures are checked for: downloaded artificial intelligence language model tools
07.10mAISecOrganizational.3	10.m Control of Technical Vulnerabilities	Do not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against: - precision and specificity of outputs configured to limit adversary's ability to extract information from model
07.10mAISecOrganizational.4	10.m Control of Technical Vulnerabilities	Do not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against these configurations: - configured to apply output encoding on textual outputs
07.10mAISecOrganizational.5	10.m Control of Technical Vulnerabilities	Do not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against these configurations: - configured to

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			limit/throttle total number and rate of API calls a user can make
07.10mAISecOrganizational.6	10.m Control of Technical Vulnerabilities	Do not have assurance that inspections were carried out on all AI software assets in use.	Management should ensure that inspections are carried out on all AI software assets prior to their use.
0701.07a1Organizational.7	07.a Inventory of Assets	All inventories are not formally documented.	Management should ensure that all inventories for in-scope assets are maintained in accordance with the requirement statement.
0704.07a1Organizational.8	07.a Inventory of Assets	All inventories are not formally documented.	Management should ensure that all inventories for in-scope assets are maintained in accordance with the requirement statement.
0704.07a1Organizational.9	07.a Inventory of Assets	Operating system, primary/secondary administrator, primary users not currently included within the asset inventory.	Management should ensure that they update the asset inventory to address all components addressed within the requirement statement.
0715.10m1Organizational.4	10.m Control of Technical Vulnerabilities	Not currently documented.	Management should ensure that documentation is updated to include the components outlined within the requirement statement.
0732.09r1Organizational.3	09.r Security of System Documentatio n	Share permissions are currently being worked on to ensure that documents are only shared to specific drives rather than the entire organization.	Management should ensure that permissions within the environment are adjusted to ensure users only have access to drives that they need access to.
08.09m1Organizational.8	09.m Network Controls	Documentation does not outline how Merge is ensuring that users cannot access unknown and/or malicious	Management should update current documentation to outline the technical tools in place to ensure users cannot access unknown

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		websites.	and/or malicious websites.
0815.01o1Organizational.1	01.o Network Routing Control	Currently implemented, but not documented.	Management should update the current documentation to address the components outlined within the requirement statement.
0825.09m1Organizational.14	09.m Network Controls	Documentation does not outline the mechanisms in place for ensuring IDS/IPS is implemented.	Update the current documentation to outline the mechanisms in place for ensuring IDS/IPS is implemented.
09.09sAISecOrganizational.1	09.s Information Exchange Policies and Procedures	Do not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against: - encryption implemented between artificial intelligence model and output interface
0905.10g1Organizational.12	10.g Key Management	Documentation needs to be improved; does not indicate the specifics for key management	Management should ensure that the current policies and procedures are updated to account for requirements regarding key management.
0931.09v1Organizational.8	09.v Electronic Messaging	DKIM and DMARC not currently implemented; Documentation does not include implementation specifics.	Management should finalize implementing DKIM and DMARC, Ensure that documentation is updated to reflect the new changes/implementations .
0936.09w1Organizational.1	09.w Interconnecte d Business Information Systems	Documentation needs to be improved; does not indicate the specifics for system management.	Management should ensure documentation is updated to include the necessary requirements for interconnected systems.
11.01cAISecSystem.5	01.c Privilege Management	AI policies and procedures considering the details of the requirement	Management should ensure that AI policies and procedures are developed considering

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		statement are not formally maintained at this time. Appropriate access controls to AI models and other assets could not be confirmed.	the following: - outlines least privilege principle for generative artificial intelligence model - outlines process for granting access to data and system capabilities for generative artificial intelligence model - outlines process for authenticating access to data and system capabilities for generative artificial intelligence model Further, management should ensure that appropriate access controls to AI models and other assets is implemented considering the following: - access to data and system capabilities limited to least privilege principle for generative artificial intelligence model
11.01cAISecSystem.6	01.c Privilege Management	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time. Appropriate access controls to AI models and other assets could not be confirmed.	Management should ensure that AI policies and procedures are developed considering the following: - outlines least privilege principle for generative artificial intelligence model - outlines process for granting access to data and system capabilities for generative artificial intelligence model - outlines process for authenticating access to

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			data and system capabilities for generative artificial intelligence model Further, management should ensure that appropriate access controls to AI models and other assets is implemented considering the following: - access to data used to train, test, validate, and fine-tune model is restricts according to the organization's access control program
11.01cAISecSystem.7	01.c Privilege Management	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time. Appropriate access controls to AI models and other assets could not be confirmed.	Management should ensure that AI policies and procedures are developed considering the following: - outlines least privilege principle for access to generative artificial intelligence model Further, management should ensure that appropriate access controls to AI models and other assets is implemented considering the following: - access to generative artificial intelligence model is restricted according to the organization's access control program
11.01cAISecSystem.8	01.c Privilege Management	AI policies and procedures considering the details of the requirement	Management should ensure that AI policies and procedures are developed considering the following:

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		statement are not formally maintained at this time. Appropriate access controls to AI models and other assets could not be confirmed.	- outlines least privilege principle for access to generative artificial intelligence model Further, management should ensure that appropriate access controls to AI models and other assets is implemented considering the following: - access to generative artificial intelligence model and language model tools is restricted for APIs and end-users.
11.01cAISecSystem.9	01.c Privilege Management	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time. Appropriate access controls to AI models and other assets could not be confirmed.	Management should ensure that AI policies and procedures are developed considering the following: - outlines least privilege principle for access to generative artificial intelligence model Further, management should ensure that appropriate access controls to AI models and other assets is implemented considering the following: - access to artificial intelligence engineering environment is restricted - access to artificial intelligence code used to create, train, and/or deploy models is restricted - access to artificial intelligence code of language model tools is

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			restricted
11.01q1System.3	01.q User Identification and Authentication	MFA is not currently enforced by default throughout the organization.	Management should ensure that MFA is technically enforced for all access to the in-scope environment.
11.01q1System.4	01.q User Identification and Authentication	MFA is not currently enforced by default throughout the organization.	Management should ensure that MFA is technically enforced for all access to the in-scope environment.
11.01vAISecSystem.1	01.v Information Access Restriction	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time. Do not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI policies and procedures are developed considering the following: - outlines encryption strength for artificial intelligence data at rest - outlines encryption key management for artificial intelligence data at rest Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against: Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against: - encryption implemented between artificial intelligence model and output interface
11143.02i1Organizational.3	02.i Removal of Access Rights	Process for ensuring that transfers have their access rights properly revoked/updated is not formally developed/defined.	Management should ensure that an access revocation/update process is defined and documented to ensure their access rights are accurate.
11149.02g1Organizational.2	02.g	A-LIGN was unable	Management should

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
	Termination or Change Responsibilities	to gain assurance that a termination checklist is formally maintained.	ensure that a termination checklist outlining the approved steps for termination is formally documented.
11152.02h1Organizational.1	02.h Return of Assets	A-LIGN was unable to gain assurance that a termination checklist is formally maintained.	Management should ensure that a termination checklist outlining the approved steps for termination is formally documented.
12.09abAISecSystem.3	09.ab Monitoring System Use	Do not have assurance that AI systems being used are configured as the requirement statement has outlined.	Management should ensure that AI systems being used (Vertex and Gemini) are evaluated against: - configured to allow human operators to ability to: evaluate outputs before relying on them - configured to allow human operators to ability to: intervene in model-initiated actions
12.09abAISecSystem.4	09.ab Monitoring System Use	Do not have assurance that AI systems being used are monitored as outlined within the requirement statement.	Management should ensure that AI systems being used (Vertex and Gemini) are monitored and consider the following: - monthly monitoring/review performed on artificial intelligence inputs to identify anomalies - monthly monitoring/review performed on artificial intelligence outputs to identify anomalies
12.09abAISecSystem.5	09.ab Monitoring System Use	Do not have assurance that AI systems being used are monitored as outlined within the requirement	Management should ensure that AI systems being used (Vertex and Gemini) are monitored and consider the following:

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		statement.	- monthly monitoring/review performed on artificial intelligence for suspicious manipulation of: AI-related datasets - monthly monitoring/review performed on artificial intelligence for suspicious manipulation of: AI models - monthly monitoring/review performed on artificial intelligence for suspicious manipulation of: AI-relevant code - monthly monitoring/review performed on artificial intelligence for suspicious manipulation of: AI-relevant configurations
12.09abAISecSystem.6	09.ab Monitoring System Use	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time. Do not have assurance that AI systems being used are monitored as outlined within the requirement statement.	Management should ensure that AI policies and procedures are developed considering the following: - outlines artificial intelligence log management process Management should ensure that AI systems being used (Vertex and Gemini) are monitored and consider the following: - logging includes: the exact input - logging includes: the date and time of the input - logging includes: the user account making the request

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			- logging includes: where the request originated - logging includes: the exact output provided - logging includes: the version of the model used - logs managed in accordance with organization's audit logging and monitoring program
12148.06i1Organizational.1	06.i Information Systems Audit Controls	A-LIGN was unable to gain assurance that the types of logs that Merge will audit on a continued basis are included within the formally defined policies and procedures.	Management should ensure that the types of events Merge will be auditing on a continued basis are formally defined.
1295.09af1System.2	09.af Clock Synchronizatio n	Clock synchronization not currently in place.	Management shall ensure that in-scope network devices utilizes 2 different time sources to validate the time events occur within the in-scope environment.
13.02eAISecOrganizational.1	02.e Information Security Awareness, Education, and Training	Formal AI training is not completed at this time.	Management should ensure that formal AI training is completed on at least an annual basis and considers the following: - artificial intelligence training provided on: development - artificial intelligence training provided on: data science - artificial intelligence training provided on: cybersecurity - artificial intelligence training is provided at least annually to all appropriate parties
14.05iAISecOrganizational.1	05.i Identification	AI Model cards are not maintained at this	Management should ensure that for any

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
	of Risks Related to External Parties	time, nor are they reviewed prior to the deployment of AI models in production applications	internally produced AI system, AI Model cards are developed, maintained, and reviewed prior to deployment.
14.05kAISecOrganizational.1	05.k Addressing Security in Third Party Agreements	Assurance could not be obtained demonstrating that contracts and agreements with Google outline the details of the requirement statement.	Management should ensure that contracts and agreements with Google consider the following: Provide evidence that an agreement was executed that included security requirements for AI models for all selected samples. Provide evidence that an agreement was executed that included security requirements for AI datasets for all selected samples. Provide evidence that an agreement was executed that included security requirements for AI software packages for all selected samples. Provide evidence that an agreement was executed that included security requirements for AI platforms and computing infrastructure for all selected samples. Provide evidence that an agreement was executed that included security requirements for AI language model tools for all selected samples. Provide evidence that an agreement was executed that included contracted AI system-related services for all selected samples.
14.09fAISecSystem.1	09.f Monitoring and Review of	Do not have assurance that inspections were	Management should ensure that inspections are carried out on all AI

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
	Third Party Services	carried out on all AI software assets in use and annually after deployment.	software assets prior to their use and annually thereafter.
1419.05j1Organizational.12	05.j Addressing Security When Dealing with Customers	Terms and conditions or the product/service, right to monitor, liability, and acknowledgement are not currently in place	Management should ensure that that proper terms and conditions are added to the website
15.11cAISecOrganizational.1	11.c Responsibilities and Procedures	The Incident Response Plan does not address how to respond to an AI-specific incidents. A dedicated AI-specific incident response test is not completed on at least an annual basis.	Management should ensure that the Incident Response Plan addresses how to respond to an AI-specific incidents. Management should ensure that a dedicated AI-specific incident response test is completed on at least an annual basis. Further, management should ensure that alerting and logging of AI events are integrated to the incident response plan.
1561.11c1Organizational.4	11.c Responsibilities and Procedures	A-LIGN was unable to gain assurance that incident detection, eradication and containment steps are inclided within the formally defined policy.	Management should ensure that the necessary components outlined within the requirement statement are formally defined.
1569.11e1Organizational.12	11.e Collection of Evidence	Incident response plan does not include the required components for the collection, retention, and presentation of evidence for legal cases.	Update incident response plan to outline collection, retention, and presentation of evidence requirements for legal cases.
16.09l1Organizational.4	09.l Back-up	Control not currently	Management should

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		implemented.	ensure that backups within the in-scope environment are made immutable.
16.09lAISecOrganizational.1	09.l Back-up	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time. AI backups are not performed based on the requirement statement.	Management should ensure that AI policies and procedures are developed considering the following: - outlines process for backing up AI assets and data Further management should ensure that backups consider the following: - backups are configured for: training, test, and validation datasets - backups are configured for: code used to create, train, and/or deploy AI models - backups are configured for: tuning data - backups are configured for: models - backups are configured for: language model tools (e.g., plugins, agents) - backups are configured for: AI system configurations (e.g., meta prompts) - backups are configured for: prompt enhancement data for RAG
16.12bISO23894Organizational.1	12.b Business Continuity and Risk Assessment	An AI system business impact analysis is not completed at this time.	Management should ensure that an AI system business impact analysis is completed on at least an annual basis
1611.09h1System.2	09.h Capacity Management	A-LIGN was unable to gain assurance that sufficient storage	Management should ensure that in-scope tools (Entra/Google) are

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		capacity has been configured/allocated.	configured to ensure current and future capacity planning is in place.
1632.12a1Organizational.1	12.a Including Information Security in the Business Continuity Management Process	A-LIGN was unable to gain assurance that the required components are addressed within the Merge documentation.	Management should ensure that the required components are added to the defined BC/DR plan.
1677.12e1Organizational.6	12.e Testing, Maintaining and Re-Assessing Business Continuity Plans	Responsibility for business continuity tests is not currently defined and implemented. Further, A-LIGN was unable to gain assurance that the annual incident response testing includes a BC/DR test as well.	Management should ensure that responsibility for business continuity tests is defined and implemented. Further, management should ensure that incident response tests also include the BC/DR capabilities of Merge.
17.00aFedRAMPOrganizational.8	00.a Information Security Management Program	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - risk assessment policy contains the purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance
17.00aNIST80053Organizational.40	00.a Information Security Management Program	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - risk assessment policy is consistent with applicable laws, Executive Orders, directives, regulations,

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			policies, standards, and guidelines. - risk assessment policy addresses organization\'s designation of an official to manage the development, documentation, and dissemination of the risk assessment policy and procedures.
17.03aISO23894Organizational.12	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines steps to understand uncertainty in all parts of the AI system, including the utilized data, software, mathematical models, physical extension, and human-in-the-loop aspects of the system - defines awareness that AI is a fast-moving technology domain - defines a consistent approach to determine the risk level - defines the organization’s AI capacity, knowledge level, and ability to mitigate realized AI risks when deciding its AI risk appetite
17.03aISO23894Organizational.15	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines whether AI systems can harm human beings, deny essential services, infringe human rights or contribute to

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			environmental harm - defines external and internal expectations for the organization's social responsibility - defines external and internal expectations for the organization's environmental responsibility
17.03aISO23894Organizational.16	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - AI system authorities defined - AI system responsibilities defined - AI system accountabilities defined - AI system roles and responsibilities communicated to workforce
17.03aISO23894Organizational.17	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines risk considerations for the organization - defines risk considerations for customers, partners, and suppliers - defines risk considerations for end users/workforce members - defines risk considerations for civil organizations (if required) - defines risk considerations for affected communities (if

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			required) - defines risk considerations for societies (if required)
17.03aISO23894Organizational.19	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines scope objectives and purpose of program
17.03aISO23894Organizational.20	03.a Risk Management Program Development	Statements related to the organization's commitment to AI risk management are not completed at this time.	Management should ensure that statements related to MERGE's commitment to AI risk management are completed to increase confidence of their stakeholders on their use of AI
17.03aISO23894Organizational.21	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that specialized resources to manage AI risk
17.03aISO23894Organizational.23	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - policies and statements related to AI risk and risk management to stakeholders.
17.03bISO31000Organizational.1	03.b Performing Risk Assessments	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - decision-related documents include

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			potential influences and limitations to risk analysis - decision-related documents communicated to decision makers Further, management should ensure risk mitigation approvals, improvement approvals, and subsequent change management related to AI changes will also need documented approvals.
17.03aISO31000Organizational.10	03.a Risk Management Program Development	Risk Management plan is "in place' but needs enhancements	Management should ensure that the risk management program/risk register within Vanta is enhanced to satisfy the HITRUST CSF
17.03aISO31000Organizational.11	03.a Risk Management Program Development	A review of the organizations risk management framework is not completed on an annual basis at this time	Management should ensure that a review of MERGE's risk management framework is completed on an annual basis and includes the following: - consideration of the suitability, adequacy, and effectiveness of the organization-selected risk management framework and the way the risk management process is integrated into the organization.
17.03aISO31000Organizational.12	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - includes knowledge and views of stakeholders - includes best available information from

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			collaborative efforts - includes inquiry from supplemental groups (as required) Further, management should ensure that the risk assessment performed is inclusive of the above statements.
17.03aISO31000Organizational.13	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - plan defines jobs with risk management authority, responsibility, and/or accountability - plan assignments communicated across the organization
17.03aISO31000Organizational.14	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - includes process to communicate/consult with stakeholders Further, management should ensure that: - communication/consultation with stakeholders is timely - communication/consultation with stakeholders is collected, collated, synthesized and shared - communication/consultation with stakeholders

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			result in improvements being made to program
17.03aISO31000Organizational.15	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - plan defines jobs with risk management authority, responsibility, and/or accountability - plan assignments communicated across the organization Further, select a sample of communications of risk management processes and results to stakeholders and examine evidence to confirm the established standards were followed.
17.03aISO31000Organizational.16	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines: time and resources required to create plan - defines: where, when, and how different types of risk management decisions are made across the organization - defines: modifying the applicable risk management decision-making processes where necessary - defines: the organization's arrangements for managing risk

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			Further, management should ensure that the risk assessment documentation plan updated every 365 days
17.03aISO31000Organizational.17	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - defines: the need to integrate risk management into the overall culture of the organization - defines: authorities, responsibilities, and accountabilities - defines: the necessary resources required - defines: the way in which conflicting objectives are dealt with - defines: measurement and reporting within the organization's performance indicators Further, management should ensure that the Risk Management program is reviewed and communicated to appropriate parties.
17.03aISO31000Organizational.4	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - program customized and implemented to fit the organization Further, the overall risk management program is:

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			- program evaluated within the past 365 days - any non-compliances are corrected within 365 days of being identified
17.03aISO31000Organizational.5	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - organization has defined the necessary scope of its risk management activities.
17.03aISO31000Organizational.6	03.a Risk Management Program Development	Human Behavior and Culture is not currently a factor within Vanta for the Risk Management Program	Management should ensure that a factor is added to Vanta to satisfy this control.
17.03aISO31000Organizational.7	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - organization has defined the necessary scope of its risk management activities. - external: social and/or cultural - external: political, legal, and/or regulatory - external: financial - external: technological - external: economic and environmental factors - external: international, national, regional, and/or local - external: key drivers and trends affecting the objectives of the organization - external: external stakeholders'

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			relationships and/or perceptions, needs, and expectations - external: contractual relationships and commitments - external: the complexity of networks and dependencies - internal: vision, mission, and/or values - internal: governance, organizational structure, roles, and/or accountabilities - internal: strategy, objectives, and/or policies - internal: the organization's culture - internal: standards, guidelines, and/or models adopted by the organization - internal: capabilities, understood in terms of resources and knowledge - internal: data, information systems and information flows - internal: relationships with internal stakeholders, taking into account their perceptions and values - internal: contractual relationships and commitments - internal: interdependencies and interconnections
17.03aISO31000Organizational.8	03.a Risk Management Program Development	Unable to confirm that Merge monitors external and internal changes and adapts the risk management framework to maintain or improve its value to the organization.	Management should ensure that Merge monitors external and internal changes and adapts the risk management framework to maintain or improve its value to the organization. Management should

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			ensure that corresponding documentation is updated accordingly.
17.03aISO31000Organizational.9	03.a Risk Management Program Development	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - resource allocation considerations: people, skills, experience, and competence - resource allocation considerations: the organization's processes, methods, and tools to be used for managing risk - resource allocation considerations: documented processes and procedures - resource allocation considerations: information and knowledge management systems - resource allocation considerations: professional development and training needs - resource allocation considerations: capabilities of, and constraints on, existing resources
17.03bAISecOrganizational.3	03.b Performing Risk Assessments	AI use centered risk assessments are not completed at this time.	Management should ensure that AI use centered risk assessments are completed on at least every 180 days and consider the following: - conducted against AI training data - formally documented - performed when AI

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			security incidents occur - identified security measures implemented
17.03bAISecOrganizational.4	03.b Performing Risk Assessments	AI use centered risk assessments are not completed at this time.	Management should ensure that AI use centered risk assessments are completed on at least every 180 days and consider the following: - reviewed prior to deployment of new models - reviewed when security incidents related to the AI system occur Further, management should ensure that as a result of risk assessments a threat register related to AI is to be maintained and updated every 180 days.
17.03bAISecOrganizational.5	03.b Performing Risk Assessments	AI use centered risk assessments are not completed at this time.	Management should ensure that AI use centered risk assessments are completed on at least every 180 days and consider the following: - reviewed prior to deployment of new models - reviewed when security incidents related to the AI system occur - reviewed when new AI security threats have been detected Further, management should ensure that as a result of risk assessments a threat register related to AI is to be maintained and

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			updated every 180 days.
17.03bISO23894Organizational.10	03.b Performing Risk Assessments	An AI Inventory is not currently maintained.	Management should ensure that an AI inventory is developed using Google sheets and contains the following details: - AI data - AI models - AI systems - Value of the asset - Nature of the asset - Both tangible (e.g. data, models, the AI system itself, the environment) and intangible (e.g., reputation, trust, individual privacy and safety).
17.03bISO23894Organizational.12	03.b Performing Risk Assessments	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - includes system life cycle for development and/or use of AI Systems
17.03bISO23894Organizational.13	03.b Performing Risk Assessments	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time. Risk Assessment will also need to address the components outlined within the requirement statement.	Management should ensure that AI policies and procedures are developed considering the following: - identifies: risk consequences to the organization itself, to individuals, communities, groups, and/or societies - identifies: differences between the groups who experience the benefits of AI systems and the groups who experience negative consequences Further, management

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			should ensure that the Merge Risk Assessment will address the components outlined within the requirement statement.
17.03bISO23894Organizational.14	03.b Performing Risk Assessments	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time. Risk Assessment will also need to address the components outlined within the requirement statement.	Management should ensure that AI policies and procedures are developed considering the following: - identifies AI risk sources related to: the organization - identifies AI risk sources related to: processes and procedures - identifies AI risk sources related to: management routines - identifies AI risk sources related to: personnel - identifies AI risk sources related to: physical environment - identifies AI risk sources related to: data - identifies AI risk sources related to: AI system configuration - identifies AI risk sources related to: deployment environment - identifies AI risk sources related to: hardware, software, network resources and services - identifies AI risk sources related to: dependence on external parties Further, management should ensure that the Merge Risk Assessment will address the components outlined within the requirement statement.

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
17.03bISO23894Organizational.15	03.b Performing Risk Assessments	An AI system assessment is not completed at this time.	Management should ensure that an AI system assessment is completed and considers the following: - contains: a description and identification of the system that has been analyzed - contains: the methodology applied - contains: a description of the intended use of the AI system - contains: the identity of the person(s) and organization that carried out the risk assessment - contains: the terms of reference and date of the risk assessment - contains: the release status of the risk assessment - contains: if and to what degree objectives have been met - assesses for undetected risks - assesses for previously assessed risks that are no longer acceptable - mitigates identified risks
17.03bISO23894Organizational.16	03.b Performing Risk Assessments	An AI system societal impact analysis is not completed at this time	Management should ensure that an AI system societal impact analysis is completed and considers the following: - includes the scope of societal impact, including who the system(s) are being used by or designed for - includes how the AI system(s) affects social and cultural values held by various affected

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			groups
17.03bISO23894Organizational.17	03.b Performing Risk Assessments	An AI system assessment is not completed at this time.	Management should ensure that an AI system assessment is completed and considers the following: - includes: types of data used from individuals - includes: intended impact of the development or use of AI - includes: potential bias impact to an individual - includes: potential impact on fundamental rights that can result in material and non-material damage to an individual - includes: potential fairness impact to an individual - includes: safety of an individual - includes: protections and mitigating controls around unwanted bias and unfairness - includes: jurisdictional and cultural environment of the individual
17.03bISO31000Organizational.1	03.b Performing Risk Assessments	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - decision-related documents include potential influences and limitations to risk analysis - decision-related documents communicated to decision makers
17.03cISO23894Organizational.2	03.c Risk Mitigation	AI policies and procedures considering the	Management should ensure that AI policies and procedures are

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		details of the requirement statement are not formally maintained at this time.	developed considering the following: - identifies key controls relevant to its development and/or use of AI systems Further, management should ensure that the Risk Assessment will also cover these topics.
17.03cISO23894Organizational.3	03.c Risk Mitigation	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - identifies and understands potential AI risks - assesses and mitigates potential AI risks Further, management should ensure that the Risk Assessment will also cover these topics.
17.03cISO31000Organizational.1	03.c Risk Mitigation	A-LIGN was unable to gain assurance that risk treatment plans are integrated into the management plans.	Management should ensure that risk treatment plans are integrated into the Merge management plans.
17.03dISO23894Organizational.1	03.d Risk Evaluation	AI policies and procedures considering the details of the requirement statement are not formally maintained at this time.	Management should ensure that AI policies and procedures are developed considering the following: - identified - quantitatively/qualitatively described - prioritized Further, management

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			should ensure that the Risk Assessment will also cover these topics.
1701.03a1Organizational.12345678	03.a Risk Management Program Development	A-LIGN was unable to gain assurance that a risk management program is implemented to the in-scope environment.	Management should ensure that a risk management program is implemented to the in-scope environment.
1702.03a2Organizational.1	03.a Risk Management Program Development	Risk assessment within Vanta is not fully outlined.	Management should ensure that the risk assessment within Vanta is generated and outlined in accordance with the requirement statement.
1705.03b2Organizational.12	03.b Performing Risk Assessments	A-LIGN was unable to gain assurance that a risk management program is implemented to the in-scope environment.	Management should ensure that a risk management program is implemented to the in-scope environment, and that a risk assessment is performed annually.
1707.03c2Organizational.2	03.c Risk Mitigation	A-LIGN was unable to gain assurance that a risk management program is implemented to the in-scope environment.	Management should ensure that a risk management program is implemented to the in-scope environment, as well as that formal Corrective Actions Plan tracking is implemented as a result of the risk assessment.
1708.03c2Organizational.12	03.c Risk Mitigation	A-LIGN was unable to gain assurance that a risk management program is implemented to the in-scope environment.	Management should ensure that a risk management program is implemented to the in-scope environment.
1734.03d1Organizational.2	03.d Risk Evaluation	Risk assessment within Vanta is not fully outlined.	Management should ensure that the risk assessment within Vanta is generated and outlined in accordance with the requirement statement and that change

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			management/SDLC is covered and addressed within the risk assessment.
1739.05d1Organizational.3	05.d Authorization Process for Information Assets and Facilities	Documentation will need to be updated to include the implementation of Vanta.	Management should ensure that the current documentation is updated to address new implementations within the in-scope environment.
1744.05f1Organizational.23	05.f Contact with Authorities	A-LIGN was unable to gain assurance that key contacts are included within the business continuity and incident response plans.	Management should ensure that key contacts and their contact information (email/phone number) are included within the annually reviewed business continuity and incident response plans.
18128.08m1Organizational.12	08.m Removal of Property	Requirements not currently outlined and defined.	Management should ensure that a list, process, and training requirements for the removal of equipment (USBs) is formally outlined and defined.
1857.08c1Organizational.1	08.c Securing Offices, Rooms, and Facilities	Documentation does not currently address the required components.	Management should ensure that current documentation is updated to address the components within the requirement statement, as well as that health/safety are addressed within the risk assessment.
1880.08g1Organizational.6	08.g Equipment Siting and Protection	Current risk assessment does not address environmental hazards.	Management should ensure that environmental factors/hazards are included within the risk assessment.
19.06aAISecOrganizational.1	06.a Identification of Applicable Legislation	An assessment to identify and evaluate compliance with applicable legal and regulatory requirements addressing the	Management should ensure that an assessment to identify and evaluate compliance with applicable legal and regulatory requirements addressing the

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
		development and deployment of AI systems is not completed.	development and deployment of AI systems is completed on at least an annual basis.
19.06cAISecOrganizational.1	06.c Protection of Organizational Records	An assessment to identify and evaluate compliance with applicable legal and regulatory requirements addressing the development and deployment of AI systems is not completed.	Management should ensure that an assessment to identify and evaluate compliance with applicable legal and regulatory requirements addressing the development and deployment of AI systems is completed on at least an annual basis. Management should ensure that an assessment to identify and evaluate compliance with applicable legal and regulatory requirements addressing the development and deployment of AI systems is completed on at least an annual basis, or upon significant changes to the model, and considers the following: - includes compliance with applicable: laws - includes compliance with applicable: regulatory requirements - includes compliance with applicable: contractual obligations - includes compliance with applicable: self-imposed data governance requirements - includes compliance with applicable: copyrights or commercial interests and considers the following: - includes compliance with applicable: laws

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			- includes compliance with applicable: regulatory requirements - includes compliance with applicable: contractual obligations - includes compliance with applicable: self-imposed data governance requirements - includes compliance with applicable: copyrights or commercial interests
19.09zAISecOrganizational.1	09.z Publicly Available Information	AI release documentation is not maintained at this time	Management should ensure that AI release documentation is maintained and considers the following: limits the release of technical AI project details including: technical architecture of the overall AI system - limits the release of technical AI project details including: datasets used for training, testing, validating, and tuning of confidential and/or closed-source AI models - limits the release of technical AI project details including: datasets used for prompt augmentation via RAG - limits the release of technical AI project details including: algorithm(s) used to create confidential and/or closed-source AI models - limits the release of technical AI project details including: architecture of confidential and/or closed-source AI models - limits the release of

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
			technical AI project details including: language model tools used such as agents and plugins - limits the release of technical AI project details including: safety and security checkpoints built into the AI system - limits the release of technical AI project details including: information on teams developing and supporting the AI system
19.13jAISecOrganizational.1	13.j Data Minimization	Reviews of the data used to train AI models, fine-tune AI models, and enhance AI prompts are not completed at this time.	Management should ensure that reviews of the data used to train AI models, fine-tune AI models, and enhance AI prompts completed based on the following: - reviews data used to train AI models to identify any data fields or records that can be omitted or anonymized - reviews data used to fine-tune AI models to identify any data fields or records that can be omitted or anonymized - reviews data used to enhance AI prompts via RAG to identify any data fields or records that can be omitted or anonymized
19131.05e1Organizational.45	05.e Confidentiality Agreements	NDA template does not include the applicable laws and regulations that will need to be reviewed.	Management should ensure that the current NDA template is updated to address the components outlined within the requirement statement.
19165.07e1Organizational.13	07.e Information Labeling and	Electronic Labeling not currently in place.	Management should ensure that information is labelled according to its

DRAFT

Related HITRUST CSF Control	Reference	Gap Overview	Description of Recommendation
	Handling		classification.
19180.09z1Organizational.2	09.z Publicly Available Information	Handbook does not currently contain the appropriate language.	Management should ensure that the appropriate language outlined within the requirement statement. Further, management should ensure that a formal list of workforce members who are allowed to post with formal review and approval of the designated workforce members is maintained.
19249.06b1Organizational.2	06.b Intellectual Property Rights	Open Source change management not currently in place.	Management should ensure that a streamlined change management process for any type of approved open source software is implemented.
19922.06f1Organizational.2	06.f Regulation of Cryptographic Controls	Documentation does not include a procedure for the implementation of the cryptographic controls.	Management should ensure that a procedure for the implementation of the cryptographic controls is added to the current documentation.

DRAFT

SECTION 2

ASSESSMENT RESULTS

DRAFT

CONTROL FINDINGS

A-LIGN identified opportunities for remediation during the Gap Assessment and made recommendations on how to proceed. The attached offline spreadsheet shows the results for all the requirements tested.

Merge - 2026 - HITRUST r2 Gap Asse

CONCLUSION & RECOMMENDATIONS

HITRUST CSF is an enterprise-wide control framework that requires significant resource commitment from organizations to achieve compliance. Based on the work performed by A-LIGN and the information provided by MERGE we have outlined recommendations that will allow MERGE to become certified. The purpose of these recommendations is to allow MERGE to assess the budgetary and resource requirements to develop policies and procedures and implement necessary controls to meet the HITRUST CSF framework.

- **Control Implementation -** Implementation of HITRUST CSF control statements is required to achieve HITRUST CSF certification. MERGE is required to implement most of the CSF control statements in order to achieve certification. Currently, MERGE has 30% of the controls fully implemented. The implementation of the controls will mirror the effort required to complete the documentation.

Ongoing Commitment - Upon achieving HITRUST CSF certification MERGE will enter the Continuous Monitoring phase i.e. every control statement should be operating effectively as defined. The level of effort required to achieve HITRUST CSF certification is similar to the effort required to maintain certification. Although the Continuous Monitoring occurs over 12 months (during Interim Assessment and re-certification accordingly), MERGE's management should be aware of the commitment made to ongoing cost and resource allocations required to maintain certification. Management should also consider measuring and managing their controls improve their overall security posture and maturity score.

DRAFT

SUMMARY SCORES

To be eligible for a certification review, an organization must achieve weighted scores of **at least 62+% per domain** (Maturity Rating equivalent of '3' minimum). Note that Policy carries a 15% weight, Process is 20%, Implemented is 40%, Measured is 10%, and Managed is 15%. Below is a summary score per domain based on the results of this assessment.

Domain	Policy	Process	Implemented	Weighted Total
Information Protection Program	X	X	47.1%	18.82%
Endpoint Protection	X	X	100.0%	40.00%
Portable Media Security	X	X	55.0%	22.00%
Mobile Device Security	X	X	100.0%	40.00%
Wireless Security	X	X	N/A	N/A
Configuration Management	X	X	37.5%	15.00%
Vulnerability Management	X	X	29.3%	11.74%
Network Protection	X	X	85.0%	34.00%
Transmission Protection	X	X	58.3%	23.33%
Password Management	X	X	100.0%	40.00%
Access Control	X	X	57.1%	22.86%
Audit Logging and Monitoring	X	X	25.0%	10.00%
Education, Training and Awareness	X	X	80.0%	32.00%
Third-Party Assurance	X	X	50.0%	20.00%
Incident Management	X	X	50.0%	20.00%
Business Continuity & Disaster Recovery	X	X	8.3%	3.33%
Risk Management	X	X	11.3%	4.51%
Physical & Environmental Security	X	X	66.7%	26.67%
Data Protection & Privacy	X	X	17.5%	7.00%

DRAFT